

Meteora

Dynamic AMM 0.5.3

Smart Contract Security Assessment

January 2026

Prepared for:
Meteora

Prepared by:
Offside Labs

Sirius Xie
Ronny Xing





Contents

1	About Offside Labs	2
2	Executive Summary	3
3	Summary of Findings	5
4	Key Findings and Recommendations	6
4.1	Missing Validation on metadata_program in initialize_ permissioned_pool IX	6
4.2	Precision Loss in Vault Deposits Can Skew Initial Stable Pool Price	6
4.3	Informational and Undetermined Issues	7
5	Disclaimer	8



1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **\$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **\$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.



<https://offside.io/>



<https://github.com/offsidelabs>



https://twitter.com/offside_labs



2 Executive Summary

Introduction

Offside Labs completed a security audit of *Dynamic AMM* smart contracts, starting on January 21th, 2026, and concluding on January 27th, 2026.

Project Overview

Dynamic AMM Pools are designed to provide sustainable liquidity for decentralized finance by leveraging a capital allocation layer. Rather than relying on unsustainable liquidity mining incentives, Dynamic AMM deposits assets directly into this layer, where they are dynamically allocated to external lending protocols. This allows LPs to earn yield and rewards on idle assets. By reducing dependence on liquidity mining, Dynamic AMM mitigates issues like token inflation and short-term liquidity loss, instead fostering long-term liquidity provision. This approach emphasizes value creation and aims to attract committed LPs to the ecosystem.

Release 0.5.3 adds an operator account and permission control mechanism, enables controlled protocol fee withdrawal with on chain conversion and treasury collection, strengthens validation of recipient accounts and related parameters, fixes stable pool creation failures caused by precision loss when interacting with the vault, and upgrades Anchor to 0.31.1 with corresponding changes to vault interaction and related implementations.

Audit Scope

The assessment scope contains mainly the smart contracts of the amm program for the *Dynamic AMM* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- Dynamic AMM
 - Codebase: <https://github.com/MeteoraAg/meteora-dynamic-amm>
 - Release 0.5.3: [PR-201](#)
 - Commit Hash: 0009c3acb77b3c5b48f45fdcb4dab04e4cabca65

The issues described in this report have been resolved by the following commit:

- Dynamic AMM
 - Codebase: <https://github.com/MeteoraAg/meteora-dynamic-amm>
 - Commit Hash: 0b32f7fafcdbeb60befe95f68114216f996a877e

We listed the files we have audited below:

- Dynamic AMM Release 0.5.3
 - programs/amm/src/access_control.rs
 - programs/amm/src/constants.rs
 - programs/amm/src/curve/curve_constant_product.rs



- programs/amm/src/depeg/marinade.rs
- programs/amm/src/depeg/solido.rs
- programs/amm/src/depeg/spl_stake_pool.rs
- programs/amm/src/error.rs
- programs/amm/src/instructions/admin/auth.rs
- programs/amm/src/instructions/admin/ix_close_operator_account.rs
- programs/amm/src/instructions/admin/ix_create_operator_account.rs
- programs/amm/src/instructions/admin/mod.rs
- programs/amm/src/instructions/bootstrap_liquidity.rs
- programs/amm/src/instructions/create_lock_escrow.rs
- programs/amm/src/instructions/create_mint_metadata.rs
- programs/amm/src/instructions/initialize_pool/alpha_vault_utils.rs
- programs/amm/src/instructions/initialize_pool/initialize_customizable_permissionless_pool.rs
- programs/amm/src/instructions/initialize_pool/initialize_permissioned_pool.rs
- programs/amm/src/instructions/initialize_pool/initialize_permissionless_pool.rs
- programs/amm/src/instructions/initialize_pool/initialize_permissionless_pool_with_config.rs
- programs/amm/src/instructions/mod.rs
- programs/amm/src/instructions/operator/mod.rs
- programs/amm/src/instructions/operator/zap_protocol_fee/jup_v6_zap.rs
- programs/amm/src/instructions/operator/zap_protocol_fee/mod.rs
- programs/amm/src/instructions/operator/zap_protocol_fee/process_zap_protocol_fee.rs
- programs/amm/src/instructions/set_pool_fee.rs
- programs/amm/src/instructions/withdraw_protocol_fees.rs
- programs/amm/src/lib.rs
- programs/amm/src/math/safe_math.rs
- programs/amm/src/state/mod.rs
- programs/amm/src/state/operator.rs
- programs/amm/src/utls.rs
- programs/amm/src/vault_utils.rs

Findings

The security audit revealed:

- 0 critical issue
- 0 high issue
- 1 medium issue
- 1 low issue
- 1 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.



3 Summary of Findings

ID	Title	Severity	Status
01	Missing Validation on metadata_program in initialize_permissioned_pool IX	Medium	Fixed
02	Precision Loss in Vault Deposits Can Skew Initial Stable Pool Price	Low	Acknowledged
03	Possible Incorrect Event Field Values in withdraw_protocol_fees IX	Informational	Fixed



4 Key Findings and Recommendations

4.1 Missing Validation on `metadata_program` in `initialize_permissioned_pool` IX

Severity: Medium

Status: Fixed

Target: Smart Contract

Category: Data Validation

Description

In Release 0.5.3, the Anchor constraint on `metadata_program` in the `initialize_permissioned_pool` IX was removed: `#[account(address = mpl_token_metadata::ID)]`. In the subsequent code, there are no further checks on this account.

As a result, in the `initialize_permissioned_pool` IX, if the admin accidentally passes an unexpected `metadata_program`, it may lead to unintended behavior due to CPI calls into an arbitrary program.

Impact

Although the `initialize_permissioned_pool` IX can only be invoked by the admin, since `CreateMetadataAccountV3` requires the payer (the admin in `initialize_permissioned_pool`) to be a writable signer, CPI into an unexpected `metadata_program` may still result in loss of funds for the admin or compromise other protocols that the admin has equivalent privileges over.

Recommendation

It's recommended to add back the check `#[account(address = mpl_token_metadata::ID)]`.

Mitigation Review Log

Fixed in the commit `0b32f7fafcdebe60befe95f68114216f996a877e`.

4.2 Precision Loss in Vault Deposits Can Skew Initial Stable Pool Price

Severity: Low

Status: Acknowledged

Target: Smart Contract

Category: Precision



Description

The relaxation of precision checks in `validate_initial_liquidity` could lead to a deviation of the pool's initial price from the stable price 1:1. For example, if the intended balanced amounts of Token A and Token B are 1:1, and the `bootstrap_liquidity` or `init_permissionless_pool_*` logic tries to deposit 2 Token A and 2 Token B into the pool, but 1 Token B is effectively lost due to vault precision loss, then the final deposited amounts become 2:1. As a result, the invariant D and the initial price are changed.

Impact

This may cause a stable pool to start in a materially imbalanced state and therefore start trading at a price that deviates from 1:1.

Recommendation

It's recommended to enforce a minimum deposited amount during initialization, for instance, requiring that the initial deposited amounts must exceed 10e6.

Mitigation Review Log

Meteora Team: It is not security issue, and we don't have users to use permissionless stable pool right now.

4.3 Informational and Undetermined Issues

Possible Incorrect Event Field Values in `withdraw_protocol_fees` IX

Severity: Informational

Status: Fixed

Target: Smart Contract

Category: Code QA

In the `withdraw_protocol_fees` instruction, when emitting `WithdrawProtocolFeesEvent`, the `Token A` and `Token B` fee amounts recorded in the event are not the actual amounts transferred out.

```
106     emit!(WithdrawProtocolFeesEvent {
107         protocol_a_fee,
108         protocol_b_fee,
109         pool: ctx.accounts.pool.key(),
```

[programs/amm/src/instructions/withdraw_protocol_fees.rs#L106-L109](#)

It's recommended to populate `WithdrawProtocolFeesEvent` with the actual withdrawn protocol fee amounts, i.e., `amount_a` and `amount_b`.



5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

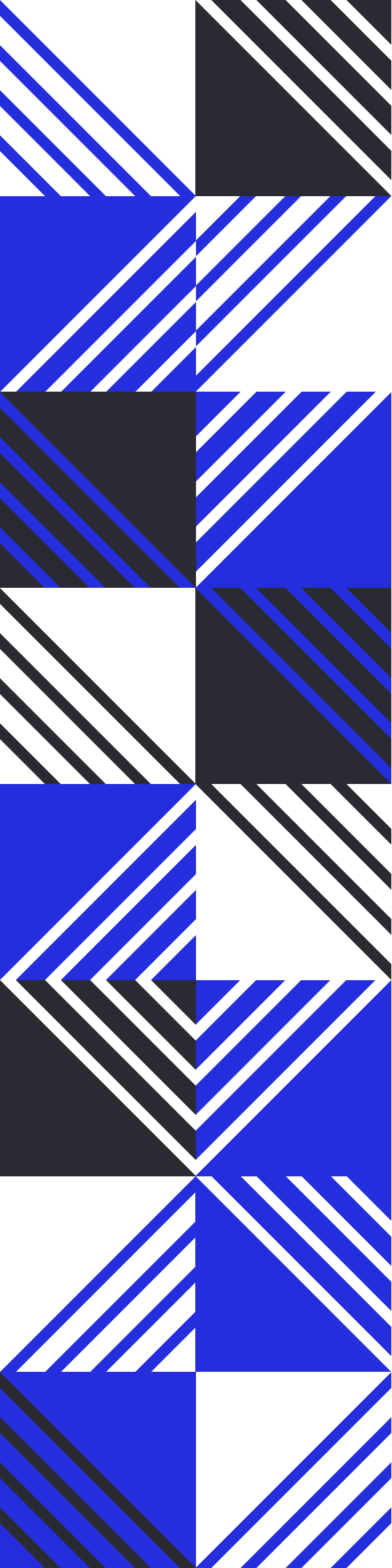
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



 <https://offside.io/>

 <https://github.com/offsidelabs>

 https://twitter.com/offside_labs